CompTIA Security+ (SY0-701)

3-Week Study Guide

Definition · Where It's Used / Scenario Cues · Advantages & Disadvantages

How to use this guide:

- Items marked [COMPARE / TRADE-OFF] test which option fits a scenario — study the ADV/DISADV to eliminate wrong answers.
- Items marked [SCENARIO RECOGNITION] test whether you can identify a concept from a described behavior — focus on the CUES.
- Items marked [PROCESS / SEQUENCE] test ORDER — these are commonly tested as 'what is the FIRST/NEXT step' questions.
- Boxed EXAM TIP callouts flag common traps and how CompTIA phrases the correct answer.

Domain 1: General Security Concepts (12%)

1.1 Security Controls

The exam loves matching a scenario description to a control CATEGORY (technical/managerial/operational/physical) and a control TYPE (preventive/deterrent/detective/corrective/compensating/directive). Memorize the grid, not just the list.

Control Categories *[SCENARIO RECOGNITION]*

Definition: Technical = enforced by systems/software (firewalls, encryption, ACLs). Managerial = policies/governance decisions (risk assessments, security policy). Operational = enforced by people/day-to-day procedures (security guards, awareness training). Physical = tangible barriers (locks, fencing, badges).

Scenario cues — how to spot it: Ask 'who/what enforces this?' A firewall rule = technical. A policy document = managerial. A guard checking IDs = operational or physical (guard = operational function, badge reader = physical). If the exam says 'a written policy requiring X' → managerial.

Example: 'The organization mandates annual risk assessments' = Managerial control.

Control Types *[SCENARIO RECOGNITION]*

Definition: Preventive = stops the incident before it happens (firewall, MFA). Deterrent = discourages an attacker without physically stopping them (warning signs, lighting). Detective = identifies an incident during/after (IDS, logs, CCTV review). Corrective = fixes/limits damage after detection (patching, restoring backup). Compensating = alternative control when the primary isn't feasible (extra logging when patching isn't possible). Directive = tells people what to do (policy, SOP, mandatory training).

Scenario cues — how to spot it: Timing is the key differentiator: BEFORE = preventive/deterrent, DURING/AFTER = detective, AFTER (fix) = corrective. 'Can't apply the real fix so we add X instead' = compensating.

Example: A legacy system can't be patched, so it's placed on an isolated VLAN with extra monitoring = compensating control.

1.2 Fundamental Concepts

CIA Triad *[SCENARIO RECOGNITION]*

Definition: Confidentiality (prevent unauthorized disclosure), Integrity (data hasn't been altered), Availability (systems accessible when needed).

Scenario cues — how to spot it: Data was viewed by someone unauthorized → confidentiality breach. Data was changed/corrupted → integrity breach. System is down/DoS → availability breach.

Example: A DDoS attack targets availability. A hash mismatch on a downloaded file indicates an integrity issue.

AAA Framework *[COMPARE / TRADE-OFF]*

Definition: Authentication (proving identity), Authorization (what you're allowed to do), Accounting (logging what was done).

Where it's used: RADIUS/TACACS+ servers, login systems, network access control.

Advantages: Provides a full audit trail and enforces least privilege alongside identity verification.

Disadvantages: Adds complexity/latency; accounting logs must be protected and can grow large.

Zero Trust *[COMPARE / TRADE-OFF]*

Definition: 'Never trust, always verify' — no implicit trust based on network location. Control Plane (Policy Engine, Policy Administrator, adaptive identity, threat scope reduction) decides policy; Data Plane (Policy Enforcement Point, subject/system, implicit trust zones) enforces it.

Where it's used: Modern hybrid/cloud enterprise networks replacing perimeter-based trust.

Advantages: Limits lateral movement, reduces blast radius of a breach, works well for remote/hybrid workforces.

Disadvantages: Complex to implement, requires strong identity infrastructure, can add authentication overhead.

Deception Technology *[SCENARIO RECOGNITION]*

Definition: Honeypot (fake single system), Honeynet (fake network of systems), Honeyfile (fake attractive file), Honeytoken (fake credential/data record used as a tripwire).

Scenario cues — how to spot it: If the scenario mentions a decoy system/file specifically meant to detect or waste an attacker's time.

Example: A fake 'passwords.xlsx' file that alerts security when opened = honeyfile.

Physical Security Controls *[SCENARIO RECOGNITION]*

Definition: Bollards (block vehicles), access control vestibule/mantrap (one person at a time), fencing, CCTV, guards, badges, lighting, sensors (infrared/pressure/microwave/ultrasonic detect motion).

Scenario cues — how to spot it: Look for the specific PHYSICAL mechanism named — the exam often tests which sensor type or barrier fits a scenario.

Example: Preventing tailgating into a server room = access control vestibule.

1.3 Change Management

Change Management Process (security-relevant elements) *[PROCESS / SEQUENCE]*

- **Request/Approval process** — Formal request submitted and approved by change advisory board/owner before work begins.
- **Impact analysis** — Assess what systems/stakeholders are affected and the risk of the change.
- **Test results** — Validate the change in a non-production environment first.
- **Backout plan** — Defined rollback procedure if the change fails — always required for security-critical changes.
- **Maintenance window** — Scheduled low-impact time to implement, minimizing downtime.
- **Documentation update** — Diagrams and policies/procedures updated to reflect the new state.

> **EXAM TIP:** *Exam angle: a change made WITHOUT going through this process is itself a security risk (unauthorized/undocumented change = common wrong-answer trap and correct-answer trigger for 'what should have been done').*

1.4 Cryptographic Solutions

Symmetric vs Asymmetric Encryption *[COMPARE / TRADE-OFF]*

Definition: Symmetric = same key encrypts & decrypts (AES). Asymmetric = key pair, public encrypts/private decrypts or vice versa (RSA, ECC).

Where it's used: Symmetric: bulk data encryption (disk, files) because it's fast. Asymmetric: key exchange, digital signatures, certificates because it solves key distribution.

Advantages: Symmetric = fast, efficient for large data. Asymmetric = solves the key-distribution problem, enables non-repudiation via signatures.

Disadvantages: Symmetric = key distribution/sharing is a challenge (how do both parties get the same key safely?). Asymmetric = computationally slower, not ideal for bulk data.

PKI Components *[SCENARIO RECOGNITION]*

Definition: Public key (shared freely), Private key (kept secret), Key escrow (a trusted third party holds a copy of keys for recovery).

Scenario cues — how to spot it: 'Recovering an employee's encryption key after they leave' → key escrow.

Example: A CA issuing a certificate signed with its private key, verifiable by anyone with the CA's public key.

Certificate Concepts *[SCENARIO RECOGNITION]*

Definition: CA (issues certs), CRL (list of revoked certs), OCSP (real-time revocation check), Self-signed (not issued by a trusted CA — internal/test use), Root of trust (the base CA everything chains to), CSR (request sent to a CA to get a cert issued), Wildcard cert (covers *.domain.com).

Scenario cues — how to spot it: 'Checking in real time if a cert is still valid' = OCSP. 'A downloadable list checked periodically' = CRL. 'One cert for all subdomains' = wildcard.

Example: A browser warning about an untrusted certificate authority likely involves a self-signed cert.

Hashing vs Encryption vs Encoding *[COMPARE / TRADE-OFF]*

Definition: Hashing = one-way fixed-length fingerprint for integrity (SHA-256). Encryption = two-way, reversible with a key, for confidentiality. Encoding (e.g., obfuscation techniques) = reformatting data, not for security by itself.

Where it's used: Hashing: password storage, file integrity verification, digital signatures. Encryption: protecting confidentiality of data at rest/in transit.

Advantages: Hashing is fast and verifies data hasn't changed. Encryption protects secrecy.

Disadvantages: Hashing alone doesn't protect confidentiality (hash of a known value can be reversed via rainbow table) — this is why SALTING is added.

Salting & Key Stretching *[SCENARIO RECOGNITION]*

Definition: Salting = random data added to a password before hashing so identical passwords don't produce identical hashes (defeats rainbow tables). Key stretching = deliberately slows down hash computation (PBKDF2, bcrypt) to resist brute force.

Scenario cues — how to spot it: 'Two users with the same password have different hashes in the database' = salting is in use. 'Hashing algorithm intentionally takes longer to compute' = key stretching.

Example: bcrypt used for password storage is both salted and stretched.

Obfuscation Methods *[SCENARIO RECOGNITION]*

Definition: Steganography (hiding data inside another file, e.g. an image), Tokenization (replacing sensitive data with a non-sensitive token, original stored elsewhere), Data masking (showing partial/fake data, e.g. XXXX-XXXX-XXXX-1234).

Scenario cues — how to spot it: 'Credit card shown with only last 4 digits' = masking. 'Sensitive value swapped for a random reference value used in transactions' = tokenization. 'Secret message hidden inside a picture file' = steganography.

Example: A payment processor storing a token instead of the real card number = tokenization.

Crypto Hardware Tools *[SCENARIO RECOGNITION]*

Definition: TPM (chip on the motherboard for hardware-based key storage/boot integrity), HSM (dedicated hardware appliance for managing/storing keys at scale, often in a data center), Secure enclave (isolated CPU area for sensitive processing, e.g. mobile devices).

Scenario cues — how to spot it: 'Laptop full-disk encryption tied to the motherboard' = TPM. 'Centralized key management appliance for an enterprise' = HSM.

Example: BitLocker uses the TPM to seal the encryption key to the hardware.

Domain 2: Threats, Vulnerabilities, and Mitigations (22%)

2.1 Threat Actors & Motivations

Threat Actor Types *[SCENARIO RECOGNITION]*

Definition: Nation-state (highest resources/sophistication, espionage/war), Unskilled attacker/script kiddie (low skill, uses existing tools), Hacktivist (politically/ideologically motivated), Insider threat (internal access, can be malicious or unintentional), Organized crime (financially motivated, well-resourced), Shadow IT (not malicious — employees using unauthorized tech, but creates risk).

Scenario cues — how to spot it: Match MOTIVE + SOPHISTICATION + INTERNAL/EXTERNAL to the actor. 'Employee installs unauthorized cloud storage app' = Shadow IT (not a classic 'attacker'). 'Defaces a website to protest a company policy' = hacktivist.

Example: A well-funded, highly sophisticated group targeting critical infrastructure for espionage = nation-state.

Motivations *[SCENARIO RECOGNITION]*

Definition: Data exfiltration, espionage, service disruption, blackmail, financial gain, philosophical/political beliefs, ethical (white-hat disclosure), revenge, disruption/chaos, war.

Scenario cues — how to spot it: The exam often gives a scenario and asks WHY — read for the outcome the actor wanted, not just what they did.

2.2 Threat Vectors & Attack Surfaces

Vector Categories *[SCENARIO RECOGNITION]*

Definition: Message-based (email, SMS, IM), Image-based (malicious code hidden in an image), File-based, Voice call (vishing), Removable device (USB drop attacks), Vulnerable/unsupported software, Unsecure networks (wireless/wired/Bluetooth), Open service ports, Default credentials, Supply chain (MSP/vendor/supplier compromise).

Scenario cues — how to spot it: 'Attacker leaves infected USB drives in the parking lot' = removable device vector. 'Compromise of a third-party software update mechanism' = supply chain vector.

Social Engineering Techniques *[SCENARIO RECOGNITION]*

Definition: Phishing (email), Vishing (voice), Smishing (SMS), Pretexting (fabricated scenario to gain trust), Impersonation, Business Email Compromise (BEC — impersonating an executive/vendor to redirect payment), Watering hole (compromising a site the victim frequents), Typosquatting (similar-looking domains), Brand impersonation, Misinformation/disinformation.

Scenario cues — how to spot it: 'Fake invoice email appearing to come from the CFO requesting a wire transfer' = BEC. 'Malicious site registered as gooogle.com' = typosquatting. 'Attacker compromises a site employees regularly visit rather than attacking them directly' = watering hole.

Example: A call pretending to be from IT support asking for a password = vishing + pretexting combined.

2.3 Vulnerability Types

Application Vulnerabilities *[SCENARIO RECOGNITION]*

Definition: Memory injection, Buffer overflow (writing beyond allocated memory), Race conditions — TOC (time-of-check) vs TOU (time-of-use) mismatch, Malicious update (supply-chain-poisoned patch).

Scenario cues — how to spot it: 'A value is checked, then changed before it's actually used' = race condition/TOCTOU. 'Input exceeds the buffer and overwrites adjacent memory' = buffer overflow.

Web Vulnerabilities *[SCENARIO RECOGNITION]*

Definition: SQL injection (malicious SQL in input fields to manipulate a database), XSS/Cross-site scripting (malicious script injected into a trusted webpage, runs in victim's browser).

Scenario cues — how to spot it: 'Input like `' OR 1=1--` submitted in a login form' = SQLi. 'A comment field on a website executes JavaScript when viewed by other users' = XSS.

Example: An attacker enters `<script>` tags into a public comment box that later runs for every visitor = stored XSS.

Other Vulnerability Categories *[SCENARIO RECOGNITION]*

Definition: Hardware (firmware, EOL, legacy), Virtualization (VM escape — breaking out of a VM to the host; resource reuse — data leaking between VMs sharing hardware), Cloud-specific, Supply chain (service/hardware/software provider), Cryptographic, Misconfiguration, Mobile (side loading — installing apps outside official store; jailbreaking — removing OS restrictions), Zero-day (unknown/unpatched vulnerability with no fix yet).

Scenario cues — how to spot it: 'No patch exists yet and it's being actively exploited' = zero-day. 'An attacker on a VM accesses the host or other VMs' = VM escape.

2.4 Indicators of Malicious Activity

Malware Types *[SCENARIO RECOGNITION]*

Definition: Ransomware (encrypts data, demands payment), Trojan (disguised as legitimate software), Worm (self-replicating, spreads without user action), Spyware (covertly gathers info), Bloatware (unwanted pre-installed software, low direct threat), Virus (needs a host file/user action to spread), Keylogger (records keystrokes), Logic bomb (triggers on a condition/date), Rootkit (hides deep in OS, often kernel-level, hard to detect).

Scenario cues — how to spot it: KEY DIFFERENTIATOR — Worm vs Virus: worm spreads on its own across a network; virus needs a host file and user action. 'Malware activates on the employee's termination date' = logic bomb. 'Hides itself from the OS/antivirus at a deep level' = rootkit.

Example: WannaCry spreading network-to-network without user clicks = worm behavior + ransomware payload.

Physical & Network Attacks *[SCENARIO RECOGNITION]*

Definition: RFID cloning (copying a badge's signal), Environmental attacks (HVAC/power tampering), DDoS (Distributed — many sources) — Amplified (small request → huge response, e.g. DNS amplification) vs Reflected (spoofed source IP so victim gets the reply traffic), DNS attacks, On-path/MITM, Credential replay (reusing captured auth data), Malicious code.

Scenario cues — how to spot it: 'Attacker sends small DNS queries with spoofed victim IP, causing large responses to flood the victim' = DNS amplification/reflected DDoS. 'Traffic intercepted and altered between two parties' = on-path attack.

Application & Crypto Attacks *[SCENARIO RECOGNITION]*

Definition: Injection, Buffer overflow, Replay, Privilege escalation, Forgery, Directory traversal (accessing files outside the intended directory, e.g. ../../etc/passwd), Downgrade attack (forcing weaker crypto/protocol),

Collision (two different inputs produce the same hash), Birthday attack (exploiting probability of hash collisions).

Scenario cues — how to spot it: 'URL manipulated to reach ../../../windows/system32' = directory traversal. 'Forcing a connection to use SSL instead of TLS' = downgrade attack.

Password Attacks *[SCENARIO RECOGNITION]*

Definition: Spraying (few common passwords against MANY accounts, avoids lockout), Brute force (many passwords against ONE account).

Scenario cues — how to spot it: 'Attempting "Password123" against every account in the company' = spraying. 'Thousands of attempts against a single admin account' = brute force.

Activity Indicators *[SCENARIO RECOGNITION]*

Definition: Account lockout, concurrent session usage, blocked content, impossible travel (login from two distant locations in an impossible timeframe), resource consumption/inaccessibility, out-of-cycle logging, missing logs (possible log tampering/covering tracks).

Scenario cues — how to spot it: 'User logs in from New York, then Singapore, 10 minutes later' = impossible travel. 'Logs for a specific time window are gone' = potential attacker cleanup — a red flag, not a technical glitch by default.

2.5 Mitigation Techniques

Segmentation vs Isolation *[COMPARE / TRADE-OFF]*

Definition: Segmentation = dividing a network into zones/VLANs to limit lateral movement. Isolation = completely separating a system (often air-gapped) from other networks.

Where it's used: Segmentation: separating guest Wi-Fi from corporate network. Isolation: highly sensitive systems (SCADA, classified environments) fully cut off.

Advantages: Segmentation reduces blast radius while keeping usability; isolation offers maximum protection for critical systems.

Disadvantages: Segmentation adds config complexity; isolation limits functionality/connectivity and can hamper legitimate remote management.

Hardening Techniques *[SCENARIO RECOGNITION]*

Definition: Encryption, endpoint protection installation, host-based firewall, HIPS, disabling unused ports/protocols, changing default passwords, removing unnecessary software, patching, least privilege, application allow-listing, configuration enforcement, decommissioning unused assets.

Scenario cues — how to spot it: Exam scenario: 'Server has unused services running and default credentials' → the answer is a hardening action (disable services, change defaults), not a detection tool.

Domain 3: Security Architecture (18%)

3.1 Architecture Models

Cloud vs On-Premises *[COMPARE / TRADE-OFF]*

Definition: Cloud = infrastructure hosted/managed (fully or partly) by a third-party provider. On-premises = infrastructure owned and run in-house.

Where it's used: Cloud: scalable, elastic workloads, remote-first orgs. On-prem: strict data sovereignty/compliance needs, ultra-low latency, legacy systems.

Advantages: Cloud = scalability, reduced capital expense, provider handles some security (per responsibility matrix). On-prem = full control over data/security.

Disadvantages: Cloud = shared responsibility can create gaps if misunderstood, potential vendor lock-in, less direct control. On-prem = high capital cost, harder to scale quickly, org bears full security burden.

Cloud Responsibility Matrix *[SCENARIO RECOGNITION]*

Definition: Defines what the CSP secures vs what the customer secures — varies by service model.

Scenario cues — how to spot it: IaaS = customer secures OS/apps/data, most responsibility. PaaS = customer secures apps/data only. SaaS = customer mainly secures data/access, provider handles almost everything else.

Example: In IaaS, if a VM's OS isn't patched, that's the CUSTOMER's failure, not the provider's.

Containerization vs Virtualization *[COMPARE / TRADE-OFF]*

Definition: Virtualization = full OS instances (VMs) on a hypervisor. Containerization = lightweight, shares the host OS kernel, packages app + dependencies (Docker).

Where it's used: VMs: running different OSes, strong isolation needs. Containers: microservices, fast deployment/scaling, CI/CD pipelines.

Advantages: Containers are lightweight/fast to spin up, efficient resource use. VMs offer stronger isolation (separate kernels).

Disadvantages: Containers share the host kernel = weaker isolation, a kernel exploit can affect all containers. VMs are heavier and slower to deploy.

Physical Isolation / Segmentation Tech *[SCENARIO RECOGNITION]*

Definition: Air-gapped (physically disconnected from other networks), Logical segmentation (VLANs — software-separated but same physical infra), SDN (Software-Defined Networking — centralized, programmable network control separate from hardware).

Scenario cues — how to spot it: 'No network connection at all, ever' = air-gapped. 'Separated by VLAN configuration' = logical segmentation.

Specialized Systems *[SCENARIO RECOGNITION]*

Definition: ICS/SCADA (industrial control/operational tech, often can't be patched easily — availability is priority #1 over confidentiality), RTOS (real-time OS with deterministic timing, used in critical timing systems like medical devices), Embedded systems (purpose-built, limited resources, e.g. IoT).

Scenario cues — how to spot it: 'System controls physical machinery and cannot go down for patching' = ICS/SCADA — the correct mitigation is usually compensating controls (segmentation/monitoring), NOT 'apply the patch immediately.'

Architecture Considerations *[COMPARE / TRADE-OFF]*

Definition: Availability, resilience, cost, responsiveness, scalability, ease of deployment, risk transference, ease of recovery, patch availability, power, compute.

Where it's used: Used as the decision criteria when the exam asks 'which factor should be weighed when choosing X architecture.'

Advantages: n/a — memorize the list as a checklist for scenario elimination.

Disadvantages: n/a

3.2 Securing Enterprise Infrastructure

Fail-Open vs Fail-Closed *[COMPARE / TRADE-OFF]*

Definition: Fail-open = if the security device fails, traffic is ALLOWED through. Fail-closed = if the device fails, traffic is BLOCKED.

Where it's used: Fail-open: prioritizing availability (e.g., a hospital network where blocking traffic could be life-threatening). Fail-closed: prioritizing confidentiality/security (e.g., a firewall protecting financial data).

Advantages: Fail-open keeps business running during a failure. Fail-closed guarantees no unauthorized traffic slips through during a failure.

Disadvantages: Fail-open risks a security gap during failure. Fail-closed risks a full outage during failure.

Network Appliances *[SCENARIO RECOGNITION]*

Definition: Jump server (hardened bastion host used to access other secured systems), Proxy server (intermediary for requests, can filter/cache), IDS (detects, alerts only) vs IPS (detects AND blocks inline), Load balancer (distributes traffic across servers).

Scenario cues — how to spot it: 'Detects an attack and logs an alert but doesn't stop traffic' = IDS. 'Detects AND actively drops the malicious packet' = IPS. 'Admins must connect through this hardened host before reaching production servers' = jump server.

Active vs Passive / Inline vs Tap-Monitor *[COMPARE / TRADE-OFF]*

Definition: Active device = sits directly in the traffic path and can act on it. Passive = observes a copy of traffic, can't act directly. Inline = in the direct data path (can block). Tap/monitor = receives a mirrored copy (visibility only, can't block).

Where it's used: Inline/active: IPS, firewalls (need to block). Tap/passive: traditional IDS, network monitoring tools.

Advantages: Inline can actively stop threats in real time. Tap/passive has zero impact on network performance/latency.

Disadvantages: Inline is a potential single point of failure/bottleneck. Passive/tap can only alert — can't prevent the attack.

Firewall Types *[SCENARIO RECOGNITION]*

Definition: WAF (Web Application Firewall — protects web apps specifically, Layer 7, understands HTTP/HTTPS), UTM (Unified Threat Management — all-in-one appliance bundling firewall+AV+IPS etc.), NGFW (Next-Gen Firewall — Layer 7 aware, app-level inspection, integrates IPS), Layer 4 (stateful, port/IP based) vs Layer 7 (application-aware, inspects content).

Scenario cues — how to spot it: 'Protects specifically against SQLi/XSS on a web app' = WAF. 'Single appliance combining multiple security functions for a small business' = UTM.

Port Security & Secure Access *[SCENARIO RECOGNITION]*

Definition: 802.1X (port-based network access control, requires authentication before granting network access), EAP (authentication framework used within 802.1X), VPN (encrypted tunnel for remote access), TLS vs IPSec (TLS = application-layer/transport encryption, commonly for web/browser traffic; IPSec = network-layer, encrypts entire IP packets, used for site-to-site VPNs), SD-WAN (software-defined WAN management), SASE (cloud-delivered network security + SD-WAN combined).

Scenario cues — how to spot it: 'A device must authenticate before it's even allowed onto the switch port' = 802.1X. 'Site-to-site VPN encrypting entire packets at the network layer' = IPSec.

3.3 Data Protection

Data Classifications *[SCENARIO RECOGNITION]*

Definition: Sensitive, Confidential, Public, Restricted, Private, Critical — organizational tiers determining handling requirements.

Scenario cues — how to spot it: Look for context clues on impact if disclosed: highest impact = restricted/critical/confidential; no impact = public.

Data States *[SCENARIO RECOGNITION]*

Definition: Data at rest (stored — protect via encryption/FDE), Data in transit (moving across network — protect via TLS/IPSec/VPN), Data in use (actively being processed in memory — protect via secure enclaves/memory encryption).

Scenario cues — how to spot it: Match the PROTECTION METHOD to the STATE the exam names. 'Data being processed by an application right now' = data in use — trickiest state to protect.

Data Sovereignty & Geolocation *[SCENARIO RECOGNITION]*

Definition: Data sovereignty = data is subject to the laws of the country where it's stored. Geolocation = using location data to restrict/allow access.

Scenario cues — how to spot it: 'A company must keep EU customer data physically within the EU' = data sovereignty requirement (relates to GDPR).

3.4 Resilience & Recovery

Site Types (Hot/Warm/Cold) *[COMPARE / TRADE-OFF]*

Definition: Hot site = fully equipped, near real-time failover, ready to go almost instantly. Warm site = partially equipped, some setup/data sync required. Cold site = basic facility only (power/space), longest recovery time.

Where it's used: Hot: mission-critical systems needing minimal downtime. Cold: low-priority systems, budget-constrained orgs.

Advantages: Hot = fastest recovery (low RTO). Cold = cheapest to maintain.

Disadvantages: Hot = most expensive to maintain. Cold = slowest recovery (high RTO), most manual work.

Load Balancing vs Clustering *[COMPARE / TRADE-OFF]*

Definition: Load balancing = distributes traffic across multiple servers for performance/availability. Clustering = multiple servers work together as one logical system, often with failover.

Where it's used: Load balancing: web server farms handling high traffic. Clustering: database high-availability setups.

Advantages: Load balancing improves performance and prevents overload on one node. Clustering provides automatic failover if one node dies.

Disadvantages: Load balancing alone doesn't guarantee failover of STATE. Clustering can be complex/costly to configure correctly.

Backup Types & Considerations *[SCENARIO RECOGNITION]*

Definition: Onsite/offsite, frequency, encryption, snapshots (point-in-time image, fast recovery), replication (continuous copy to another location), journaling (logs changes for precise recovery point).

Scenario cues — how to spot it: 'Need to recover to the EXACT moment before a failure, not just the last backup' = journaling. 'Instant point-in-time copy of a VM' = snapshot.

Testing Methods *[SCENARIO RECOGNITION]*

Definition: Tabletop exercise (discussion-based walkthrough, no systems touched), Simulation (mimics an actual event in a safe environment), Failover test (actually switches to backup systems), Parallel processing (backup system runs alongside production to validate).

Scenario cues — how to spot it: 'Team sits in a room and talks through what they'd do in a breach' = tabletop. 'Actually switching production traffic to the DR site to test it' = failover test.

Domain 4: Security Operations (28% — largest domain, prioritize this)

4.1 Security Techniques for Computing Resources

Secure Baselines *[SCENARIO RECOGNITION]*

Definition: Establish → Deploy → Maintain: the lifecycle of creating and enforcing a standard secure configuration.

Scenario cues — how to spot it: If a scenario is about DRIFT from a standard config, the fix is 'maintain/enforce baseline,' not 'create a new one.'

BYOD vs COPE vs CYOD *[COMPARE / TRADE-OFF]*

Definition: BYOD (Bring Your Own Device) = employee's personal device, company manages minimal policy. COPE (Corporate-Owned, Personally Enabled) = company owns device, employee can use personally. CYOD (Choose Your Own Device) = employee picks from a company-approved list, company owns it.

Where it's used: BYOD: cost-conscious orgs, flexible workforces. COPE/CYOD: orgs needing tighter control/compliance.

Advantages: BYOD = lower cost, employee comfort/familiarity. COPE/CYOD = greater company control over security posture.

Disadvantages: BYOD = harder to enforce security standards, privacy concerns, higher risk. COPE/CYOD = higher cost, less employee flexibility.

Wireless Security *[SCENARIO RECOGNITION]*

Definition: WPA3 (current strongest standard), RADIUS (centralized AAA for network access), site surveys/heat maps (used during installation planning to determine AP placement and coverage).

Scenario cues — how to spot it: 'Determining optimal access point placement before installation' = site survey/heat map.

Application Security Practices *[SCENARIO RECOGNITION]*

Definition: Input validation (reject/sanitize bad input — primary defense against injection attacks), Secure cookies (flags like HttpOnly/Secure), Static code analysis (review source code without running it), Code signing (verifies software authenticity/integrity), Sandboxing (isolated environment to run/test untrusted code).

Scenario cues — how to spot it: 'Reviewing source code for flaws WITHOUT executing it' = static analysis (dynamic analysis = WHILE running). 'Untrusted attachment opened in an isolated environment' = sandboxing.

4.2 Asset Management

Asset Lifecycle (security-relevant) *[PROCESS / SEQUENCE]*

Acquisition/procurement — Vetting and purchasing with security requirements built in.

Assignment/accounting — Ownership and classification assigned to the asset.

Monitoring/asset tracking — Inventory and enumeration to know what exists on the network at all times.

Disposal/decommissioning — Sanitization (removing data, may be reusable), Destruction (physically unusable), Certification (proof of proper disposal), Data retention (legal/compliance requirements before disposal).

> **EXAM TIP:** *Exam trap: an old hard drive being resold must be SANITIZED (wiped, verifiable), not just deleted — deletion alone leaves recoverable data.*

4.3 Vulnerability Management

Identification Methods *[SCENARIO RECOGNITION]*

Definition: Vulnerability scan, static/dynamic app analysis, package monitoring (dependency checking), threat feeds (OSINT, proprietary, info-sharing orgs, dark web), penetration testing, responsible disclosure/bug bounty programs, system/process audits.

Scenario cues — how to spot it: 'Passively collecting publicly available intel' = OSINT. 'Paying ethical hackers to find flaws' = bug bounty.

False Positive vs False Negative *[COMPARE / TRADE-OFF]*

Definition: False positive = tool flags something as a threat when it ISN'T. False negative = tool MISSES an actual threat (says all clear when it's not).

Where it's used: Both are risks in any detection tool (scanner, IDS, antivirus).

Advantages: n/a — used to test understanding of risk trade-offs when tuning detection sensitivity.

Disadvantages: False positives waste analyst time/cause alert fatigue. False negatives are MORE dangerous — a real threat goes undetected.

CVSS & CVE *[SCENARIO RECOGNITION]*

Definition: CVE = a unique ID/catalog entry for a specific known vulnerability. CVSS = a standardized SCORE (0-10) rating a vulnerability's severity.

Scenario cues — how to spot it: 'CVE-2024-XXXX' naming pattern = CVE identifier. A numeric severity score = CVSS.

Prioritization Factors *[SCENARIO RECOGNITION]*

Definition: Exposure factor (% of asset value lost), environmental variables (context-specific risk factors), industry/organizational impact, risk tolerance.

Scenario cues — how to spot it: Two vulnerabilities with the same CVSS score can have different priority if one affects an internet-facing system (higher exposure) vs an internal-only system.

Remediation Options *[SCENARIO RECOGNITION]*

Definition: Patching, insurance (risk transfer), segmentation, compensating controls, exceptions and exemptions (documented acceptance of risk for a specific case/time).

Scenario cues — how to spot it: 'Business can't patch immediately but documents WHY and adds temporary controls' = exception with compensating controls.

4.4 Alerting & Monitoring

Monitoring Tools *[SCENARIO RECOGNITION]*

Definition: SCAP (automates vuln/compliance checks), Benchmarks (baseline standards, e.g. CIS), SIEM (aggregates & correlates logs, generates alerts), DLP (blocks unauthorized data exfiltration), SNMP traps (device-triggered alerts), NetFlow (traffic metadata, not full content), Vulnerability scanners.

Scenario cues — how to spot it: 'Central platform correlating logs from firewalls, servers, and endpoints into one alert' = SIEM. 'Records source/dest IP and port info about traffic flow but not payload content' = NetFlow.

Monitoring Activities *[SCENARIO RECOGNITION]*

Definition: Log aggregation, alerting, scanning, reporting, archiving, quarantine (isolating a threat), alert tuning (reducing false positives/fatigue).

Scenario cues — how to spot it: 'Too many false alerts causing analysts to ignore real ones' = needs alert tuning.

4.5 Enhancing Enterprise Security

Email Security *[SCENARIO RECOGNITION]*

Definition: SPF (defines which servers can send mail for a domain), DKIM (cryptographically signs outgoing mail to prove it wasn't altered), DMARC (policy telling receiving servers what to do if SPF/DKIM fail — reject/quarantine/none).

Scenario cues — how to spot it: Order to remember: SPF checks the SENDING SERVER, DKIM checks the MESSAGE INTEGRITY, DMARC is the POLICY that ties both together and reports back.

Example: An email fails SPF and DKIM and the domain's DMARC policy says 'reject' → the message is blocked.

EDR/XDR vs Traditional AV *[SCENARIO RECOGNITION]*

Definition: EDR (Endpoint Detection and Response) = continuous monitoring + behavioral analysis + response capability on endpoints, goes beyond signature-based detection. XDR = extends EDR correlation across endpoints, network, cloud, email.

Scenario cues — how to spot it: 'Detects malware based on BEHAVIOR rather than a known signature, and can also respond/contain' = EDR/XDR, not traditional antivirus.

NAC & FIM *[SCENARIO RECOGNITION]*

Definition: NAC (Network Access Control) = enforces policy compliance before/during network access (e.g., device must have updated AV to connect). FIM (File Integrity Monitoring) = alerts when monitored files change.

Scenario cues — how to spot it: 'Device is denied network access because it's missing the latest patch' = NAC. 'Critical system file was modified and an alert fired' = FIM.

4.6 Identity & Access Management

Access Control Models *[COMPARE / TRADE-OFF]*

Definition: MAC (Mandatory — system-enforced labels/classifications, no user discretion, e.g. government/military), DAC (Discretionary — resource OWNER decides who gets access), RBAC (Role-Based — access tied to job role), Rule-based (access governed by predefined rules, e.g. firewall rules/time-of-day), Attribute-based (ABAC — access based on multiple attributes: user, resource, environment).

Where it's used: MAC: military/classified systems. DAC: typical file systems (Windows NTFS permissions set by the file owner). RBAC: most corporate environments (access tied to job title). ABAC: complex/dynamic environments needing fine-grained context-aware access.

Advantages: MAC = very strong, consistent security. DAC = flexible, easy for owners to manage. RBAC = easy to administer at scale, aligns with org structure. ABAC = most granular/flexible/context-aware.

Disadvantages: MAC = rigid, high administrative overhead. DAC = inconsistent, owner may grant access poorly. RBAC = role explosion in complex orgs. ABAC = complex to configure and audit.

SSO vs Federation *[COMPARE / TRADE-OFF]*

Definition: SSO = one login grants access to MULTIPLE systems WITHIN the same organization/domain. Federation = trust relationship allowing authentication ACROSS different organizations/domains.

Where it's used: SSO: internal corporate apps. Federation: 'Login with Google/Microsoft' across third-party services, partner organizations.

Advantages: Both reduce password fatigue and improve user experience; federation extends trust across organizational boundaries.

Disadvantages: Single point of failure — if the SSO/federation identity provider is compromised, ALL connected systems are at risk.

SSO Protocols *[SCENARIO RECOGNITION]*

Definition: LDAP (directory access protocol, often backend for authentication, e.g. Active Directory), OAuth (AUTHORIZATION framework — grants access to resources without sharing password, think 'app wants permission to access your data'), SAML (XML-based, used for SSO especially in enterprise/web browser contexts, combines authentication AND authorization assertions).

Scenario cues — how to spot it: 'App asks permission to access your Google contacts without seeing your password' = OAuth. 'Enterprise SSO into a web-based portal using XML assertions' = SAML.

Example: OAuth ≠ authentication protocol strictly — it's about authoriZation/delegated access; SAML handles both authentication and authorization for SSO.

MFA Factors *[SCENARIO RECOGNITION]*

Definition: Something you KNOW (password/PIN), something you HAVE (token/smart card), something you ARE (biometrics), somewhere you ARE (geolocation).

Scenario cues — how to spot it: True MFA requires factors from DIFFERENT categories — two passwords is NOT MFA (both are 'something you know'). 'Password + fingerprint' = true MFA (know + are).

Privileged Access Management *[SCENARIO RECOGNITION]*

Definition: Just-in-time permissions (temporary elevated access granted only when needed), Password vaulting (secure storage/rotation of privileged credentials), Ephemeral credentials (short-lived, auto-expiring access).

Scenario cues — how to spot it: 'Admin access automatically granted for 1 hour then revoked' = just-in-time permissions.

Password Policy Elements *[SCENARIO RECOGNITION]*

Definition: Length, complexity, reuse (prevent reusing old passwords), expiration, age (minimum time before it can be changed again), password managers, passwordless (e.g., biometrics/FIDO keys replacing passwords entirely).

Scenario cues — how to spot it: Current best practice per NIST leans toward LENGTH over frequent complexity/expiration rules — know that current guidance has shifted from 'change every 90 days' toward longer passphrases + MFA.

4.7 Automation & Orchestration

Automation Benefits vs Risks *[COMPARE / TRADE-OFF]*

Definition: Benefits: efficiency/time savings, enforcing baselines consistently, standard configs, scaling securely, faster reaction time, workforce multiplier. Risks/considerations: complexity, cost, single point of failure, technical debt, ongoing supportability.

Where it's used: CI/CD pipelines, user provisioning/deprovisioning, security orchestration (SOAR), guard rails/security groups enforcement.

Advantages: Consistent enforcement, faster response than manual processes, reduces human error.

Disadvantages: A flawed script/automation can propagate an error or a compromise at scale FASTER than a human would — 'single point of failure' is a key exam trap answer.

4.8 Incident Response

Incident Response Process (MEMORIZE THIS ORDER — heavily tested) *[PROCESS / SEQUENCE]*

1. **Preparation** — Before an incident: policies, tools, training, playbooks are ready in advance.
2. **Detection** — Identifying that an incident may be occurring (via alerts, logs, reports).
3. **Analysis** — Confirming it's a real incident, determining scope and severity.
4. **Containment** — Limiting the spread/damage (isolate affected systems).
5. **Eradication** — Removing the root cause (malware, unauthorized access).
6. **Recovery** — Restoring systems to normal operation, validating they're clean.
7. **Lessons Learned** — Post-incident review — what worked, what to improve (feeds back into Preparation).

> **EXAM TIP:** *Exam trap: don't confuse this with the vulnerability management steps or digital forensics steps — they're different sequences tested separately. Also know: Root cause analysis and Threat hunting support this process; Tabletop exercises/Simulations are used to TEST it.*

Digital Forensics Order (Chain of Custody) *[PROCESS / SEQUENCE]*

Identification/Acquisition — Collecting evidence properly (e.g., forensic imaging) without altering the original.

Preservation — Ensuring evidence integrity is maintained (write blockers, hashing to prove no tampering).

Chain of custody — Documented, unbroken record of who handled evidence and when — required for legal admissibility.

Reporting — Documenting findings.

E-discovery — Legal process of identifying/collecting electronic evidence relevant to litigation.

> **EXAM TIP:** *'Legal hold' means data must be preserved and NOT deleted because it may be relevant to a legal matter — even if normal retention policy says to delete it.*

4.9 Data Sources for Investigation

Log & Data Sources *[SCENARIO RECOGNITION]*

Definition: Firewall logs, application logs, endpoint logs, OS-specific security logs, IPS/IDS logs, network logs, metadata, vulnerability scans, automated reports, dashboards, packet captures (PCAP — full content, not just metadata).

Scenario cues — how to spot it: 'Need the actual CONTENT of network traffic, not just metadata' = packet capture (contrast with NetFlow in 4.4, which is metadata only).

Domain 5: Security Program Management and Oversight (20%)

5.1 Security Governance

Policy vs Standard vs Procedure vs Guideline *[COMPARE / TRADE-OFF]*

Definition: Policy = high-level, mandatory statement of intent (e.g., Acceptable Use Policy). Standard = specific mandatory requirements supporting a policy (e.g., password standard: min 12 characters). Procedure = step-by-step instructions to accomplish a task. Guideline = recommended, NOT mandatory, best-practice advice.

Where it's used: Policy: org-wide direction set by leadership. Standard: technical specifics enforced org-wide. Procedure: operational, task-level execution. Guideline: flexible recommendations where rigid rules don't fit.

Advantages: Together they create a governance hierarchy from strategic (policy) to tactical (procedure).

Disadvantages: n/a — exam tests you can rank these by SPECIFICITY and ENFORCEABILITY: Policy > Standard > Procedure, with Guideline being the only non-mandatory one.

Roles & Responsibilities for Data *[SCENARIO RECOGNITION]*

Definition: Owner (accountable for the data, decides classification/access — usually a business exec), Controller (determines PURPOSE and means of processing — GDPR term), Processor (processes data on behalf of the controller, e.g. a vendor), Custodian/Steward (day-to-day technical management, e.g. IT applying the access controls the owner defined).

Scenario cues — how to spot it: 'Decides WHY data is collected and how it will be used' = Controller. 'A third-party vendor that processes data per the controller's instructions' = Processor. 'IT team applying permissions per policy' = Custodian.

5.2 Risk Management

Qualitative vs Quantitative Risk Analysis *[COMPARE / TRADE-OFF]*

Definition: Qualitative = subjective ratings (High/Medium/Low) based on judgment. Quantitative = numeric, dollar-based calculations (SLE, ALE, ARO).

Where it's used: Qualitative: fast initial risk triage, less data-intensive. Quantitative: board/executive reporting requiring financial justification for security spend.

Advantages: Qualitative is quick and easy, good for prioritizing without deep data. Quantitative gives concrete, defensible financial figures for ROI/budget decisions.

Disadvantages: Qualitative is subjective, harder to justify budget with. Quantitative requires more data/time and reliable historical figures to be accurate.

Quantitative Risk Formulas (MEMORIZE) *[SCENARIO RECOGNITION]*

Definition: SLE (Single Loss Expectancy) = Asset Value × Exposure Factor. ARO (Annualized Rate of Occurrence) = how many times per year the event is expected. ALE (Annualized Loss Expectancy) = SLE × ARO.

Scenario cues — how to spot it: Exam will give you an asset value + exposure % + frequency and ask you to CALCULATE ALE — this is a guaranteed-style question. Practice the math.

Example: Asset worth $100,000, exposure factor 25% → SLE = $25,000. If expected once every 2 years → ARO = 0.5 → ALE = $12,500.

Risk Management Strategies *[COMPARE / TRADE-OFF]*

Definition: Transfer (shift risk to another party, e.g. insurance/outsourcing), Accept (Exemption = permanent approved deviation; Exception = temporary approved deviation), Avoid (eliminate the activity causing risk entirely), Mitigate (reduce likelihood/impact with controls).

Where it's used: Transfer: cyber insurance. Accept: low-impact risk where the cost of control > cost of risk. Avoid: discontinuing a risky product/service. Mitigate: applying the majority of everyday security controls.

Advantages: Transfer offloads financial burden. Accept saves cost when risk is truly low. Avoid eliminates the risk entirely. Mitigate is flexible and widely applicable.

Disadvantages: Transfer doesn't eliminate reputational damage. Accept means the risk still exists. Avoid may mean lost business opportunity. Mitigate rarely eliminates risk completely (residual risk remains).

BIA Metrics (MEMORIZE THE DEFINITIONS) *[SCENARIO RECOGNITION]*

Definition: RTO (Recovery Time Objective) = MAX acceptable time to restore a system after failure. RPO (Recovery Point Objective) = MAX acceptable amount of DATA LOSS, measured in time (how far back backups must go). MTTR (Mean Time To Repair) = average time to fix/restore a failed component. MTBF (Mean Time Between Failures) = average time a system runs before failing (reliability measure).

Scenario cues — how to spot it: RTO = 'how long can we be DOWN?' RPO = 'how much data can we afford to LOSE?' These are the #1 most-confused pair on the exam — RTO is about DOWNTIME, RPO is about DATA LOSS.

Example: If RPO = 4 hours, backups must run at least every 4 hours so no more than 4 hours of data is ever lost.

5.3 Third-Party Risk

Agreement Types *[SCENARIO RECOGNITION]*

Definition: SLA (Service-Level Agreement — defines performance/uptime guarantees), MOA (Memorandum of Agreement — formal, often with defined obligations), MOU (Memorandum of Understanding — less formal, mutual intent, not always legally binding in detail), MSA (Master Service Agreement — overarching terms for ongoing work), SOW/WO (Statement/Work Order — defines specific deliverables/scope for a project), NDA (Non-Disclosure Agreement — protects confidential info), BPA (Business Partners Agreement — defines terms of a partnership, e.g. profit sharing).

Scenario cues — how to spot it: 'Defines uptime %, response time guarantees' = SLA. 'Broad umbrella contract covering future individual projects' = MSA, with each project detailed in a SOW.

Vendor Assessment *[SCENARIO RECOGNITION]*

Definition: Penetration testing, right-to-audit clause (contractual right to audit vendor's security), evidence of internal audits, independent assessments, supply chain analysis, due diligence, conflict of interest checks, questionnaires, vendor monitoring, rules of engagement.

Scenario cues — how to spot it: 'Contract clause allowing the company to inspect the vendor's security controls' = right-to-audit clause.

5.4 Compliance

Compliance Fundamentals *[SCENARIO RECOGNITION]*

Definition: Compliance reporting (internal/external), consequences of non-compliance (fines, sanctions, reputational damage, loss of license, contractual impacts), compliance monitoring (due diligence/care, attestation, automation), privacy (data subject, controller vs processor, right to be forgotten).

Scenario cues — how to spot it: 'Right to be forgotten' = data subject can request deletion of their personal data (GDPR concept). 'Ongoing effort to actively ensure compliance' = due diligence; 'the standard of care expected' = due care.

5.5 Audits & Assessments

Internal vs External Audits *[COMPARE / TRADE-OFF]*

Definition: Internal = performed by the organization's own audit committee/self-assessment. External = performed by independent third parties (regulators, examiners).

Where it's used: Internal: ongoing self-monitoring/compliance checks. External: regulatory requirements, independent verification for stakeholders/customers.

Advantages: Internal is faster, cheaper, more frequent. External carries more credibility/independence for stakeholders and regulators.

Disadvantages: Internal may lack objectivity (self-grading). External is more costly and less frequent.

Pen Testing Environment Knowledge *[COMPARE / TRADE-OFF]*

Definition: Known environment (full information/access given — 'white box'), Partially known environment ('gray box' — some info given), Unknown environment (no info given — 'black box,' closest to a real attacker's starting position).

Where it's used: Known: thorough internal code-level testing. Unknown: realistic simulation of an external attacker.

Advantages: Known environment tests are faster/more thorough since less time is spent on recon. Unknown environment tests are the most realistic simulation of a real attack.

Disadvantages: Known environment tests are less realistic. Unknown environment tests take longer and may miss internal-only flaws due to limited access/time.

Pen Test Types & Reconnaissance *[SCENARIO RECOGNITION]*

Definition: Physical, Offensive (red team), Defensive (blue team), Integrated (purple team — collaborative), Passive reconnaissance (gathering info WITHOUT directly interacting with the target, e.g. OSINT/public records), Active reconnaissance (directly interacting/probing the target, e.g. port scanning).

Scenario cues — how to spot it: 'Looking up WHOIS records and LinkedIn employee info' = passive recon. 'Running an Nmap scan against the target's IP range' = active recon.

5.6 Security Awareness

Awareness Program Elements *[SCENARIO RECOGNITION]*

Definition: Phishing campaigns (simulated tests), anomalous behavior recognition (risky/unexpected/unintentional), user guidance/training (policy handbooks, situational awareness, insider threat awareness, password management, removable media, social engineering, operational security, hybrid/remote work), reporting and monitoring (initial + recurring), development, execution.

Scenario cues — how to spot it: Exam scenario: 'Employee clicked a simulated phishing email' → correct action is ADDITIONAL TRAINING, not punishment, in most CompTIA-preferred answers — the goal is a security-aware culture, not blame.

Suggested 3-Week Plan

Week	Focus	Daily Actions
Week 1	Domains 1 & 2 (General Concepts, Threats/Vulnerabilities/Mitigations)	Read this guide's Domain 1-2 sections. Drill acronyms 20 min/day. Do 25-30 practice questions/day on these domains.
Week 2	Domains 3, 4 & 5 (Architecture, Operations, Program Mgmt)	Read Domain 3-5 sections — spend extra time on Domain 4 (28% of exam). Continue 25-30 practice Q/day, mixed across all domains covered so far. Memorize the ALE/SLE/ARO and RTO/RPO formulas cold.
Week 3	Full review + practice exams	Take 2-3 full timed practice exams. Review every wrong answer and trace it back to this guide's relevant item. Redo weak domains. Practice PBQ-style drag/drop and matching questions. Final 2 days: acronym list + formula review only.